

What is Burp Suite?

Burp Suite is the industry-standard web application security testing tool. It sits between your browser and the web server as a proxy, letting you intercept, inspect, and modify every single HTTP request and response.

Every professional web pentester uses Burp Suite daily. Mastering it is a career skill, not just a CTF skill. The Community Edition is free and sufficient for most tasks.

Core Components

Component	What it does
Proxy	Intercepts browser↔server traffic. Core feature — everything goes through here.
Repeater	Manually resend and modify individual requests. Great for testing one payload at a time.
Intruder	Automated payload fuzzing. Brute-force parameters, headers, cookies with wordlists.
Scanner	Automatically finds vulnerabilities (Pro version). Community has limited passive scan.
Decoder	Encode/decode Base64, URL, HTML, hex — essential for CTFs.
Comparer	Diff two responses — spot what changed between requests.

Setup — Getting Started

Step 1: Configure Your Browser

```
# Firefox Setup:
```

```
Settings → General → Network Settings → Manual Proxy
```

```
HTTP Proxy: 127.0.0.1   Port: 8080
```

```
# Or install 'FoxyProxy' Firefox extension — easier to toggle on/off
```

Step 2: Install Burp Certificate (for HTTPS)

```
1. With proxy ON, visit: http://burp
```

```
2. Click 'CA Certificate' → download
```

3. Firefox → Settings → Privacy → View Certificates
→ Import → select downloaded cert → trust for websites

Key Workflows

Workflow 1: Intercept & Modify

1. Enable Intercept: Proxy → Intercept → Intercept is ON
2. Submit a form in your browser
3. Request appears in Burp – modify any parameter
4. Click 'Forward' to send it

Workflow 2: Send to Repeater

1. Right-click any request → Send to Repeater
2. Go to Repeater tab
3. Modify the request → click Send
4. See the response on the right – tweak and repeat
5. Great for testing SQLi, XSS, IDOR payloads one at a time

Workflow 3: Intruder Attack

1. Right-click request → Send to Intruder
2. Go to Intruder → Positions tab
3. Click 'Clear \$' then highlight parameter to fuzz → 'Add \$'
e.g.: password=\$test\$
4. Payloads tab → Load your wordlist (e.g., rockyou.txt)
5. Start Attack → Sort by response length – different = success!

Workflow 4: Decoder

Decoder tab → paste any encoded value:

- Detect Base64: aGVsbG8= → Decode as → Base64 → 'hello'
- URL decode: %3Cscript%3E → <script>
- Chain encodings: Base64 → URL encode → HTML encode

Your Task for Today

1. Bypass Login at <https://hackshield.onrender.com/sqli/> using Burp Suite

Reference Links

- [PortSwigger Burp Suite Official Documentation](#)
- [TryHackMe — Burp Suite Basics Room \(Free\)](#)
- [HackTheBox — Using Web Proxies Module](#)
- [Burp Suite Community Edition Download](#)
- [Rana Khalil — Burp Suite Masterclass \(YouTube\)](#)